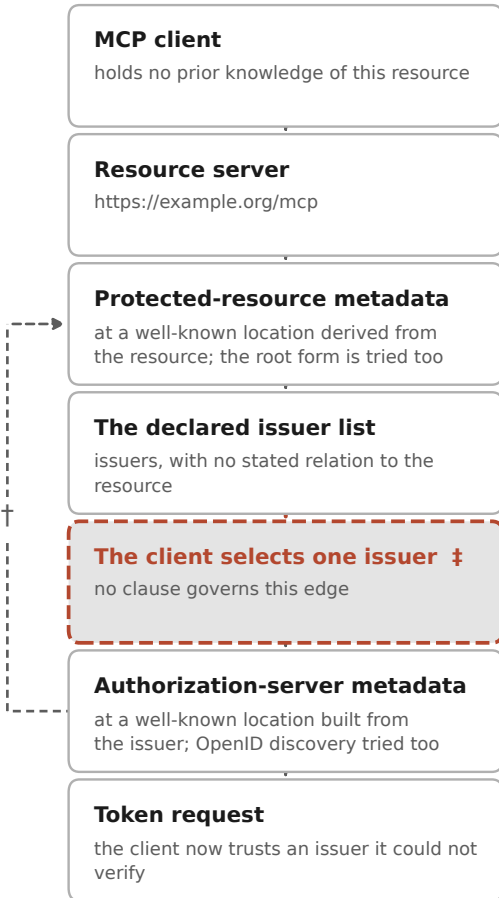




1. request → 401 carrying a pointer to the metadata

MCP Authorization, discovery (2025-06-18 MUST; 2025-11-25 one of several routes)

binds: resource server [C07]

2. fetch protected-resource metadata

RFC 9728, Section 3.2 defines it; Section 3.3 requires the identifier it declares to be identical to the one it was served under

binds: resource server [C05, C12]

3. read the declared issuers

MCP Authorization: the list MUST contain at least one entry

binds: resource server [C05]

4. choose

RFC 9728, Section 7.6: out of scope. MCP delegates the choice to the client unchanged

binds: nobody

5. fetch authorization-server metadata

RFC 8414, Section 3.3: the issuer returned MUST be identical to the issuer requested

binds: authorization server [C13]

6. authorize

RFC 9207, Section 2.3: a server supporting that specification MUST advertise its support for the issuer-identification parameter. The list of protected resources of RFC 9728, Section 4 is OPTIONAL

binds: authorization server [C16, C18]

‡ RFC 9728, Section 7.6, the clause that governs the selection step:

“Secure determination of appropriate authorization servers to use with a protected resource for all use cases is out of scope for this specification.” “... an attacker may be able to act as an adversary-in-the-middle proxy to a valid authorization server without it being detected.”

† The only mitigation Section 7.6 proposes: cross-check the resource's issuer list against the issuer's resource list.

Possible only where the authorization server publishes its own list of protected resources (RFC 9728, Section 4), which is OPTIONAL — [C18]. Whether anybody does is the quantity this study reports.